INTRODUCCIÓN AL LABORATORIO

Este informe documenta la resolución del laboratorio **Password reset broken logic**. La funcionalidad de restablecimiento de contraseña contiene un fallo de diseño lógico que permite alterar la contraseña de cualquier usuario (como `carlos`) mediante la manipulación del parámetro de nombre de usuario en el envío del formulario de cambio de clave.

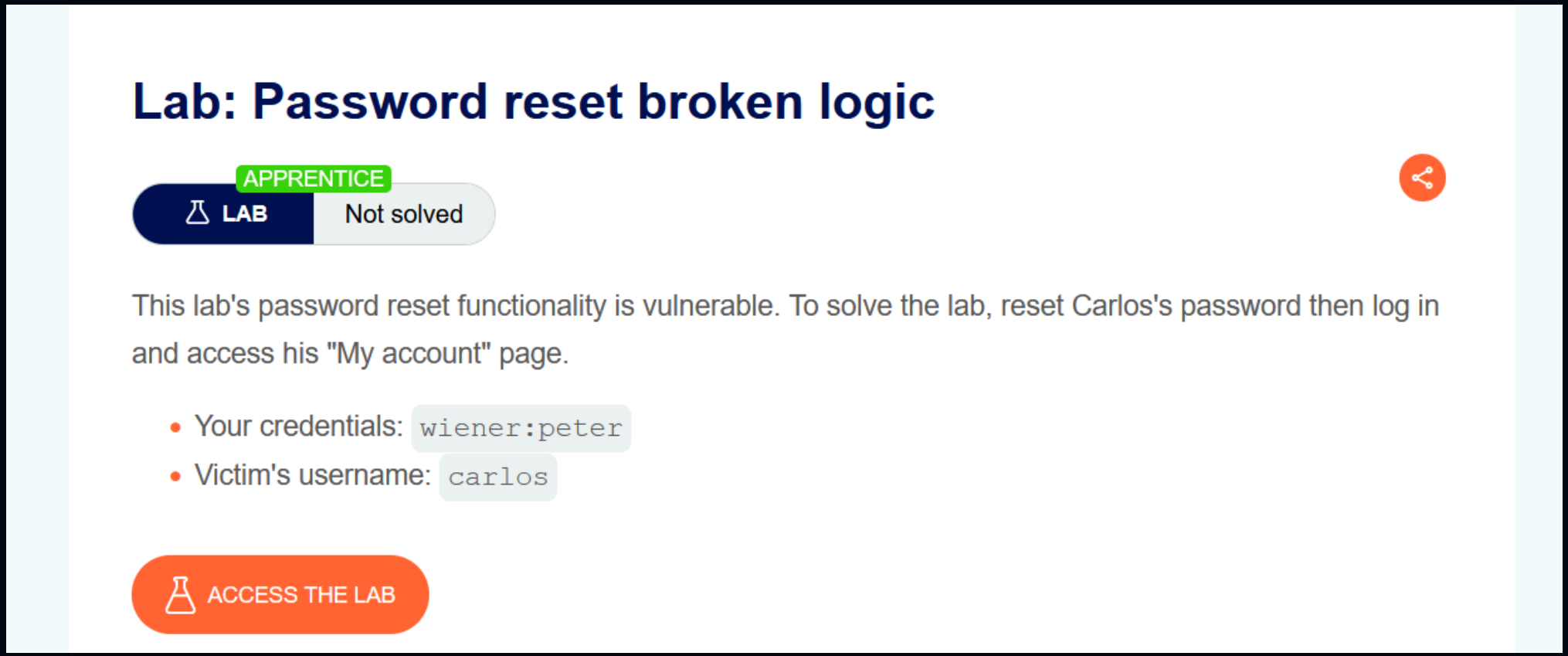
CREDENCIALES PROPORCIONADAS

Rol / Entidad	Usuario	Contraseña	Acceso a Correo
Atacante (Cuenta de prueba)	`wiener`	`peter`	SÍ (Email Client)
Víctima (Objetivo)	`carlos`	-	NO

VECTOR PRINCIPAL DE VULNERABILIDAD

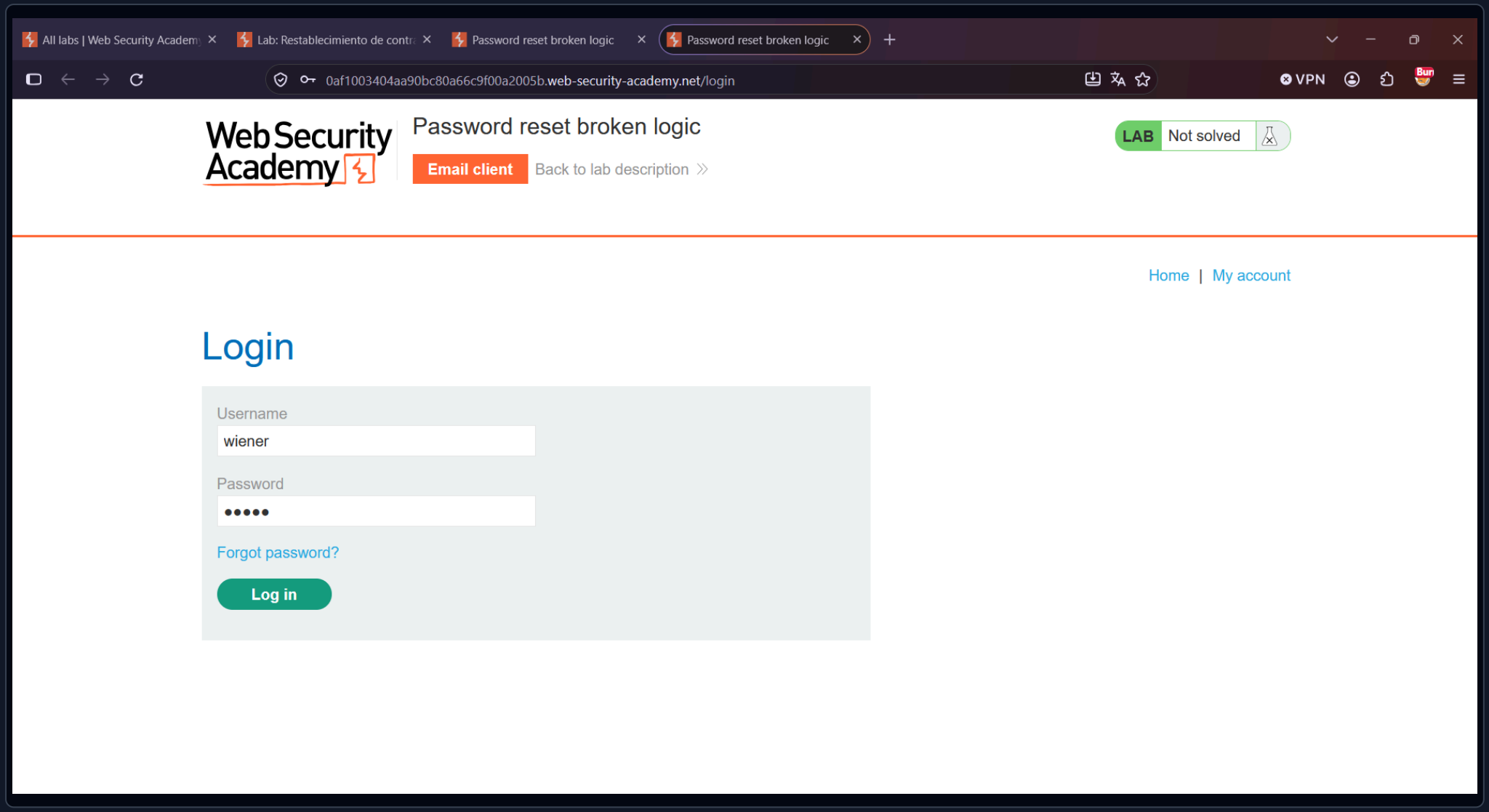
El servidor confía ciegamente en los parámetros enviados por POST durante el restablecimiento de la contraseña con token temporal, permitiendo asociar el cambio de credenciales de `wiener` a la cuenta de `carlos` alterando el campo de usuario.

01 Vista general del objetivo y credenciales base



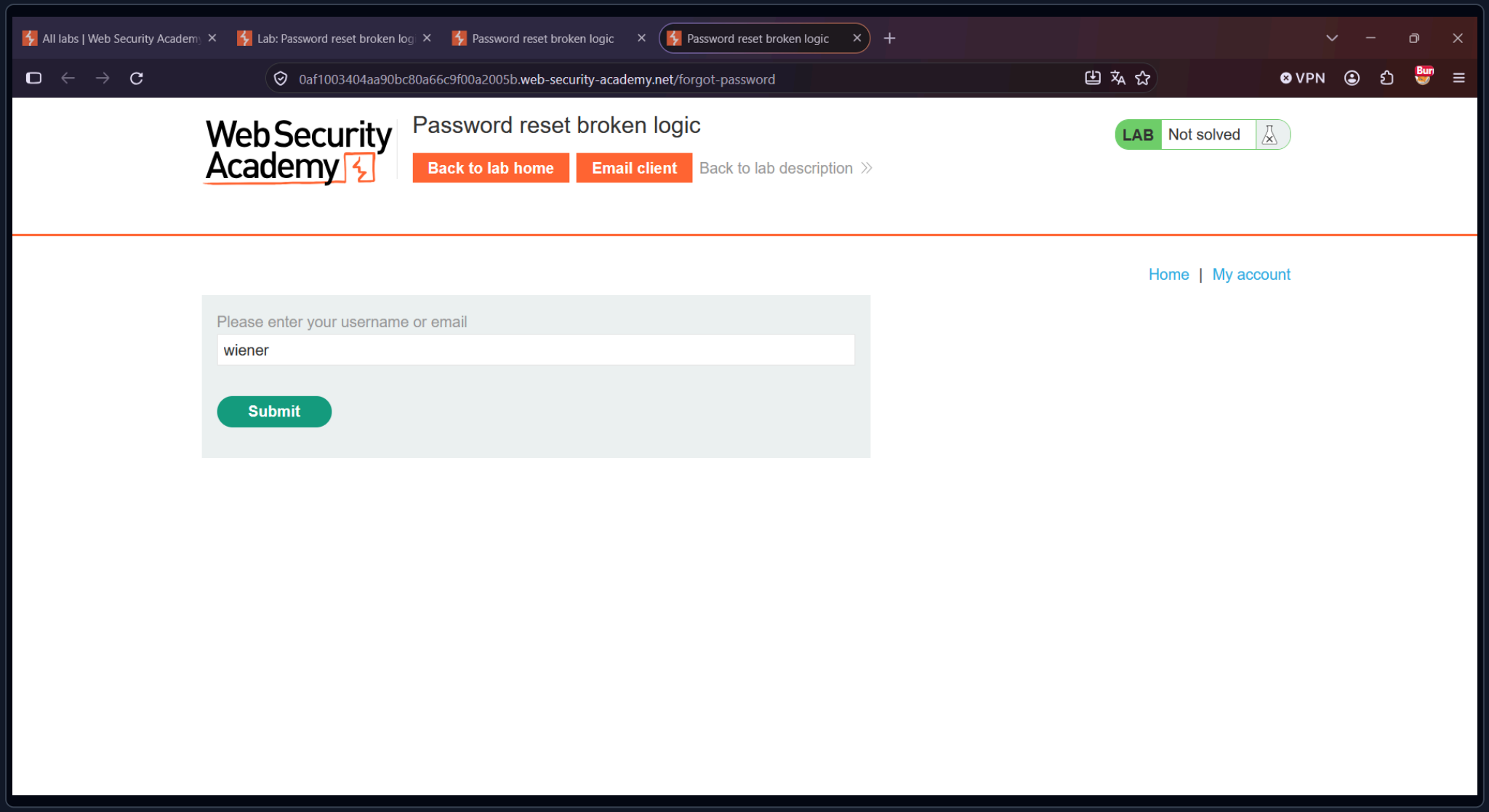
Análisis de la Captura: Se examina el enunciado oficial en PortSwigger. Se nos indica que la funcionalidad de reseteo de contraseña es vulnerable y el objetivo final es restablecer la clave de `carlos` para acceder a su página *My account*.

02 Identificación del enlace de recuperación 'Forgot password?'



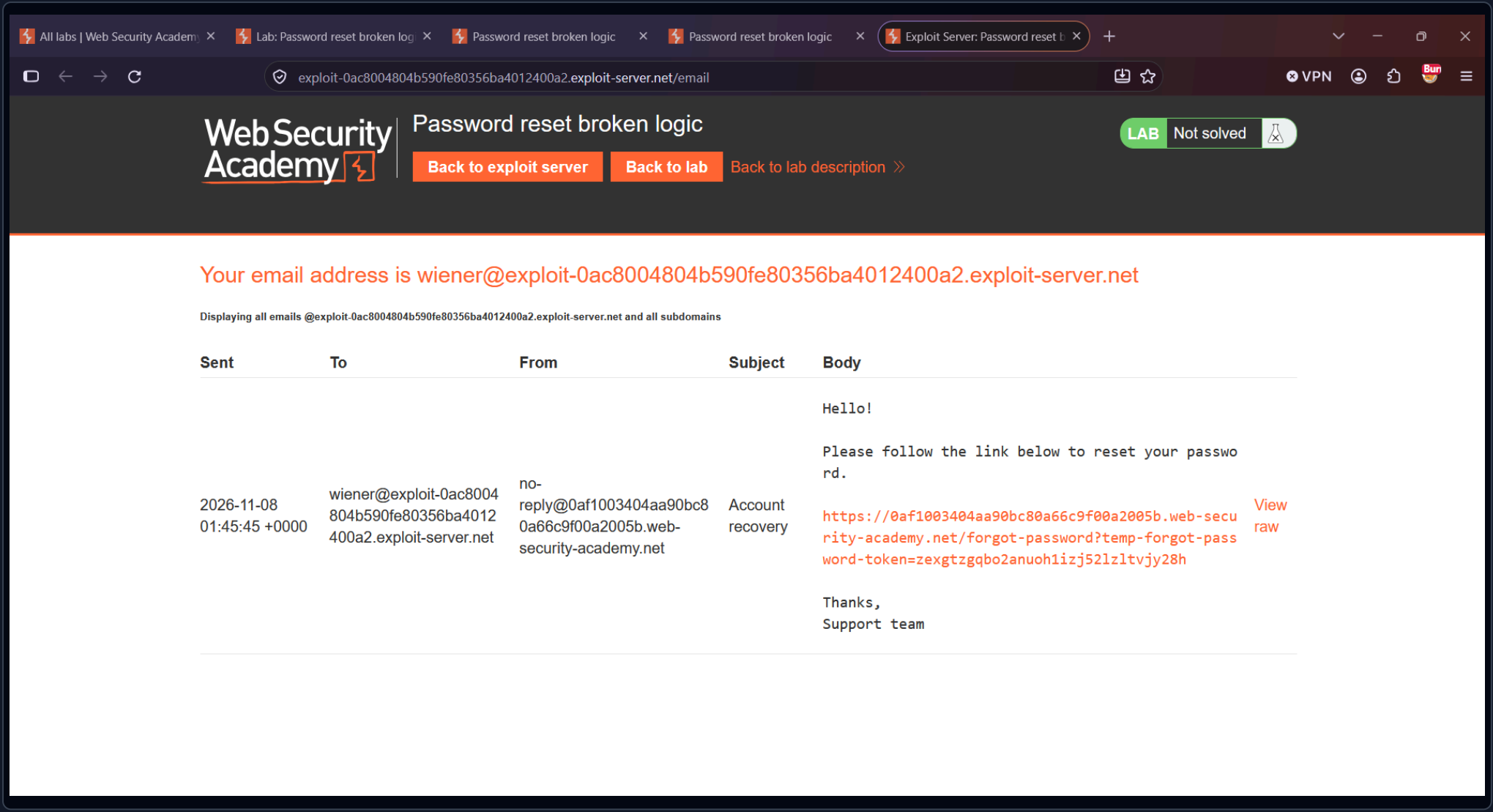
Análisis de la Captura: Navegamos al formulario de acceso de la aplicación web. Debajo de los campos de credenciales se observa claramente la opción de recuperación de contraseña `Forgot password?`, la cual inicia el flujo lógico vulnerable.

03 Introducción del usuario atacante wiener



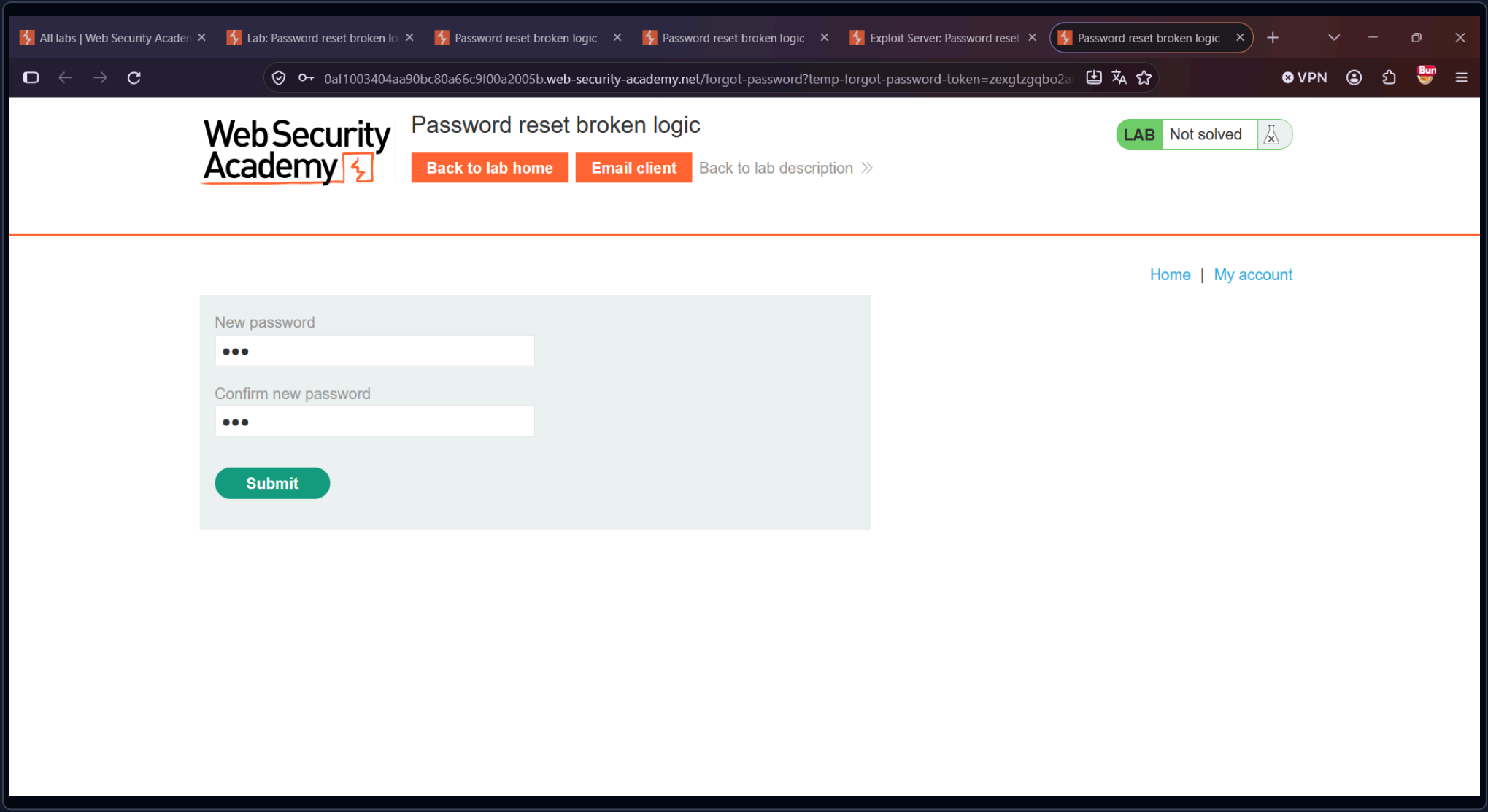
Análisis de la Captura: Solicitamos el restablecimiento de contraseña ingresando el nombre de usuario de nuestra cuenta controlada (`wiener`). Esto genera un correo electrónico con un enlace único con token temporal.

04 Extracción del enlace y token temporal del correo



Análisis de la Captura: Consultamos el cliente de correo sintético y visualizamos el mensaje recibido para `wiener`. Se obtiene la URL de recuperación que contiene el parámetro `temp-forgot-password-token=zexgtzgqbo2amuohlizj52lzltvjy28h`.

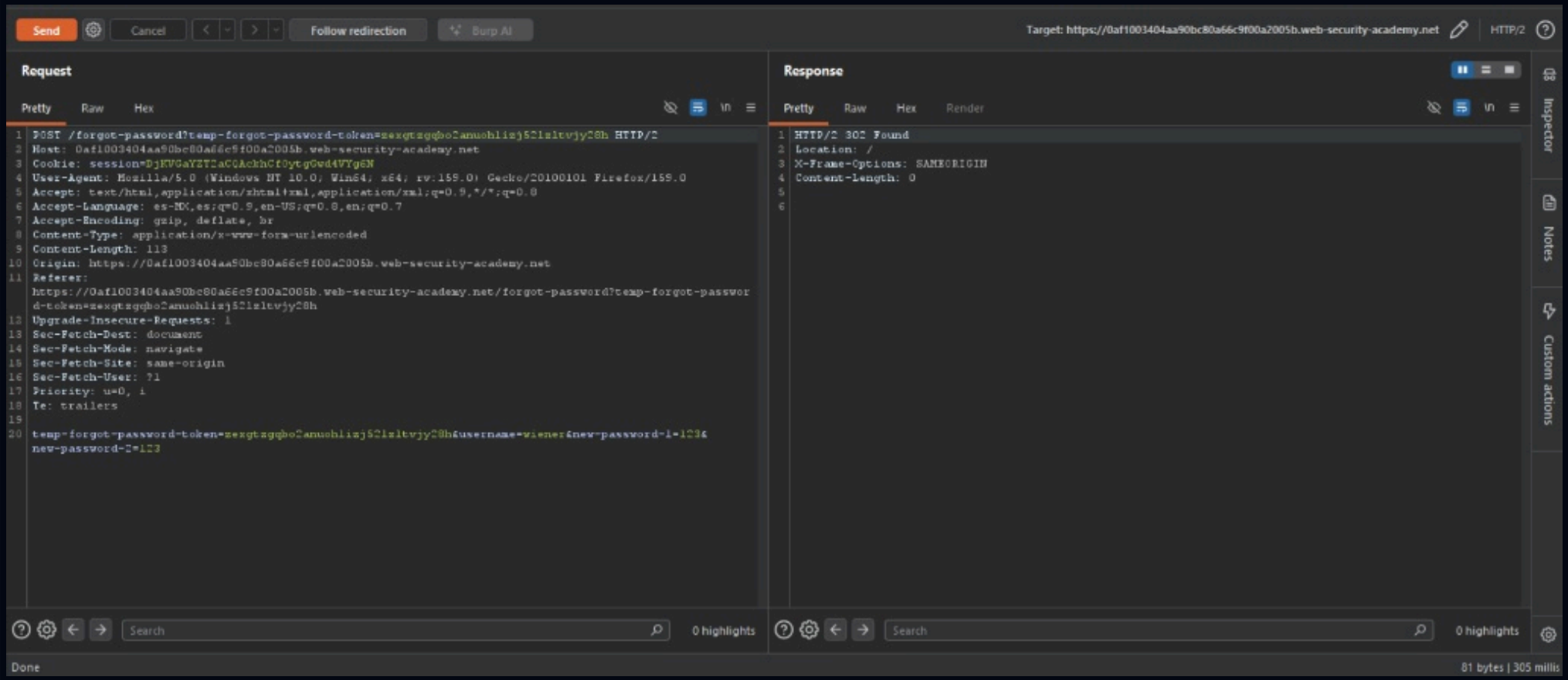
05 Acceso mediante el token obtenido al formulario de cambio



Análisis de la Captura: Al hacer clic en el enlace del correo, cargamos la interfaz para establecer la nueva contraseña y confirmar la clave. Aquí es donde Burp Suite interceptará la petición para alterar la lógica del backend.

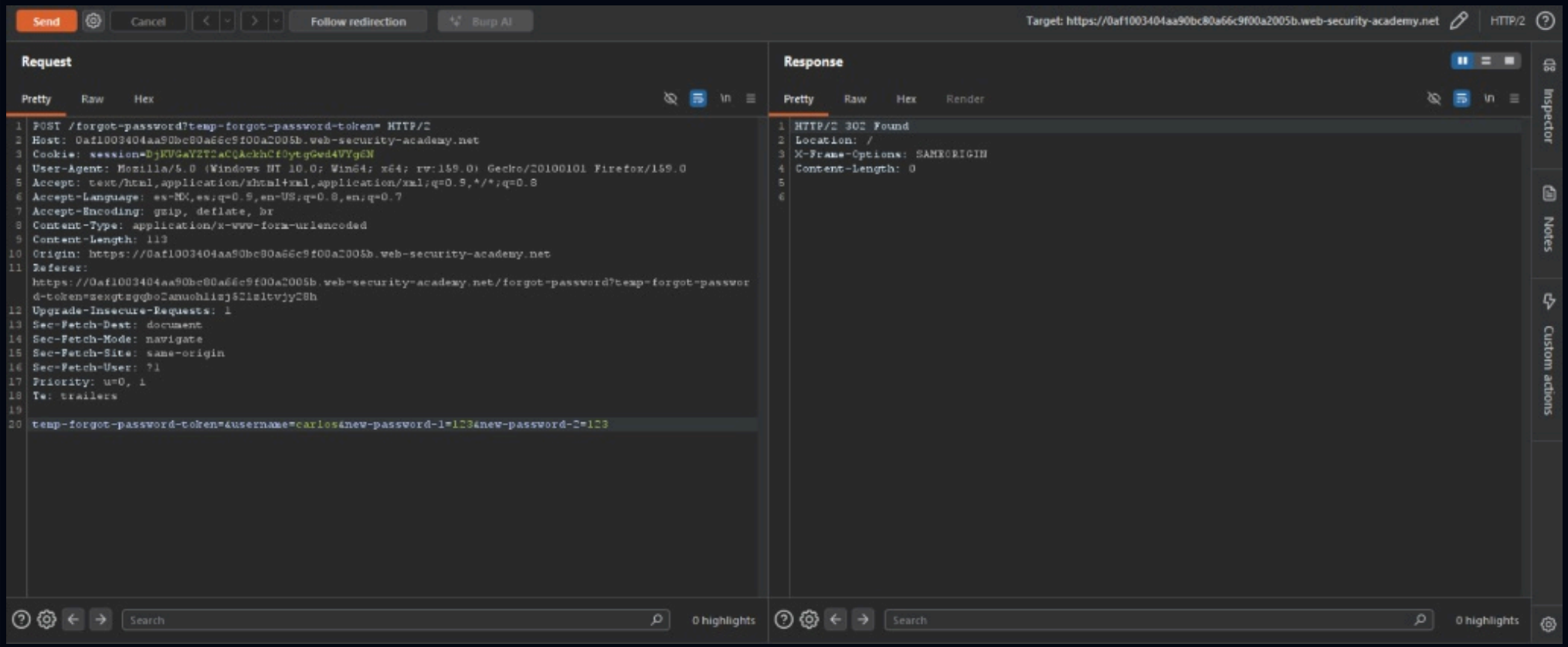
PASO 6: Interceptación en Burp Suite (Prueba con Wiener)

06 Análisis de la petición POST con username=wiener



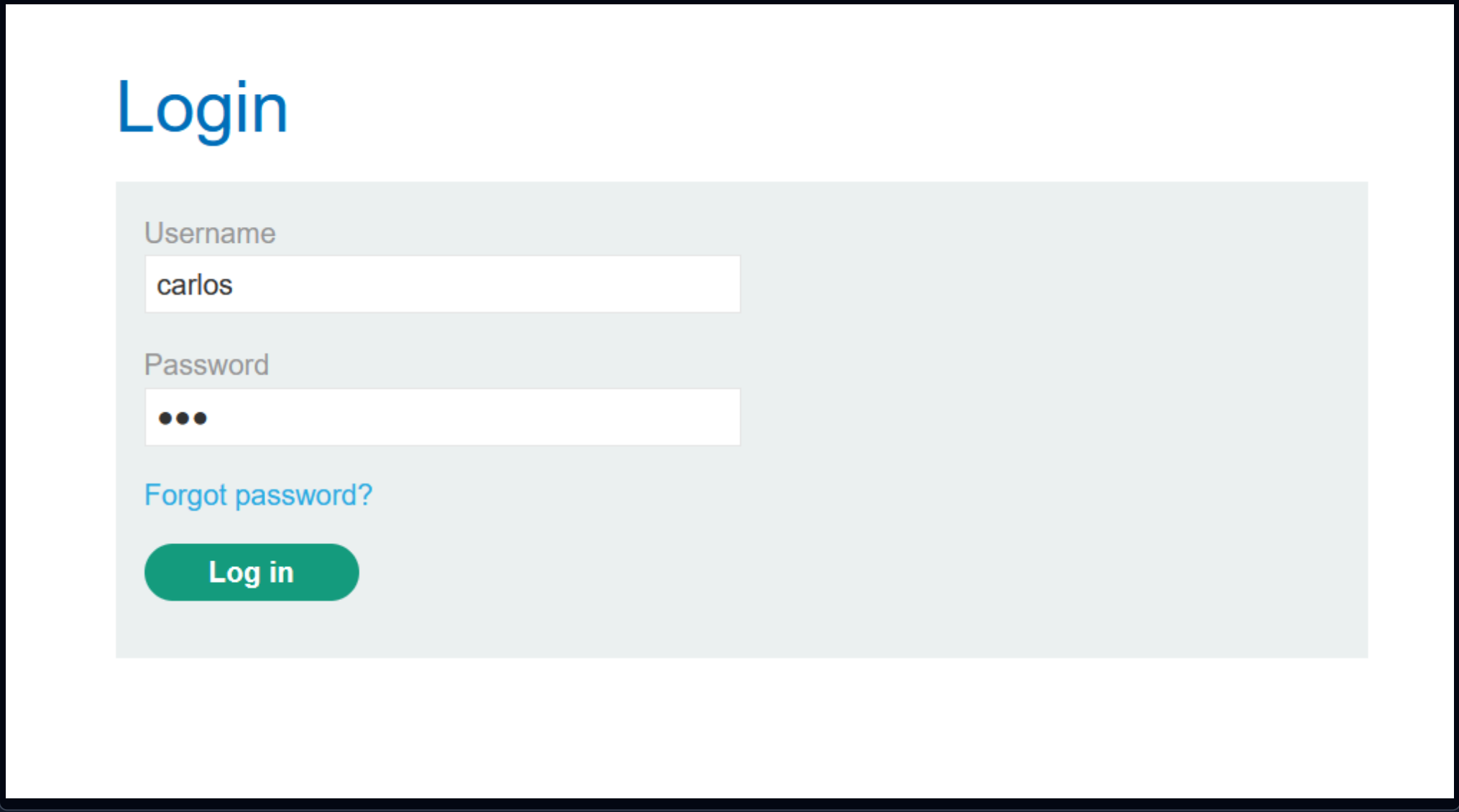
Análisis de la Captura: Capturamos la solicitud POST enviada al enviar el formulario. En el cuerpo de la petición se observa el parámetro oculto `username=wiener` junto con `new-password-1` y `new-password-2`.

07 Modificación de username=carlos y eliminación del token de wiener



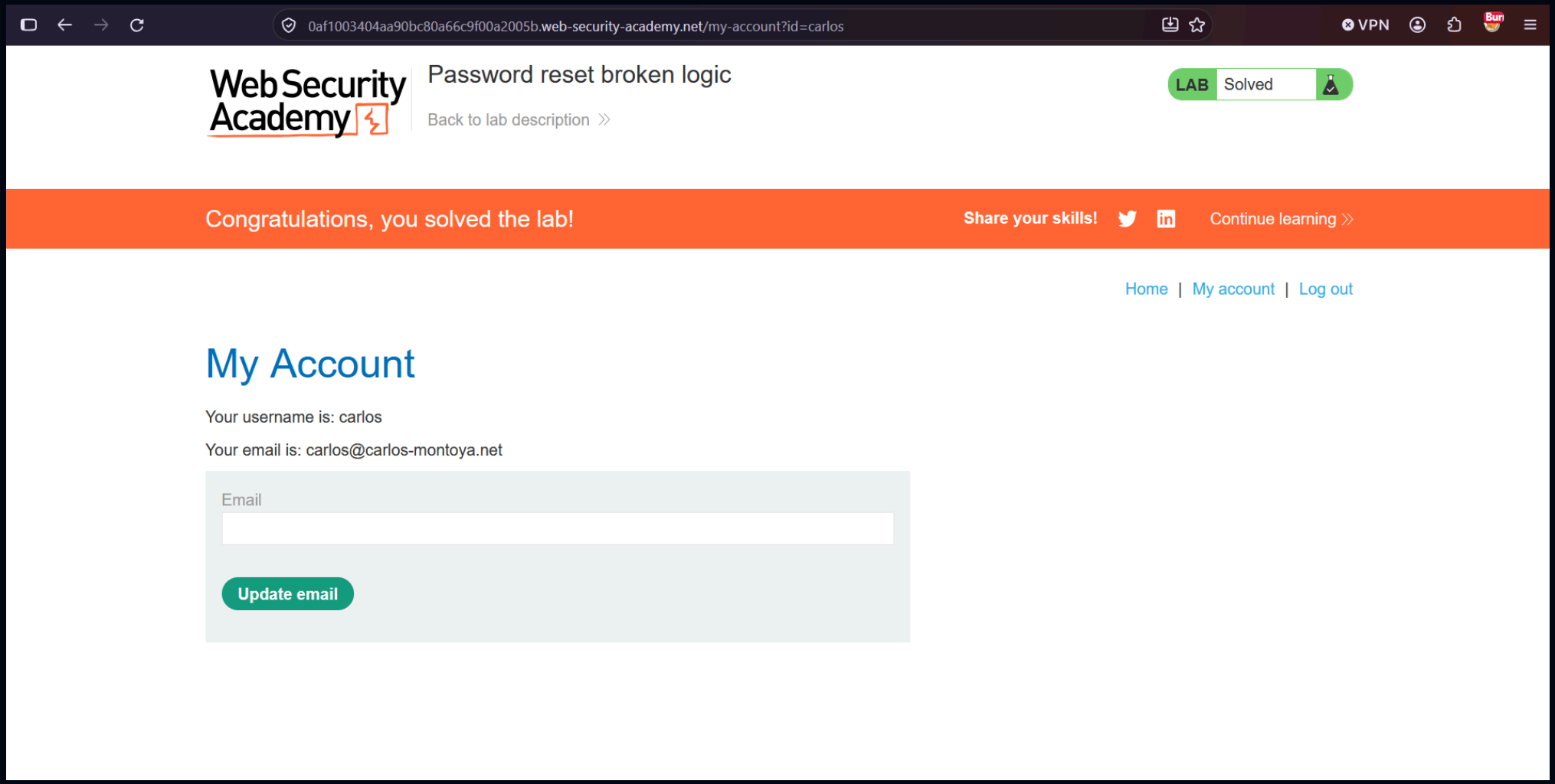
Análisis de la Captura: Explotamos la vulnerabilidad modificando el parámetro `username=carlos` y eliminando por completo el token temporal asociado a `wiener` (o vaciando el parámetro del token). Al no requerir que el token pertenezca a Carlos, el servidor procesa el cambio y actualiza la clave de la víctima.

08 Login con las nuevas credenciales de Carlos



Análisis de la Captura: Nos dirigimos nuevamente al formulario de inicio de sesión e ingresamos el usuario `carlos` junto con la contraseña que acabamos de establecer (`123`).

09 **Acceso exitoso al panel de Carlos y notificación 'Solved'**



Análisis de la Captura: El servidor autentica correctamente a `carlos`, muestra la página de su cuenta privada y la plataforma notifica el mensaje *Congratulations, you solved the lab!*.

¿POR QUÉ OCURRIÓ ESTA VULNERABILIDAD? (CAUSA RAÍZ)

La vulnerabilidad surge debido a una **falla de validación lógica en el flujo de recuperación de contraseña (Broken Object Level Authorization / Flawed State Validation)**:

- **Desacoplamiento inseguro del token:** El servidor generó y asoció correctamente un token temporal a la sesión de `wiener`, pero al procesar el cambio de clave en el POST, confió en el campo `username` enviado por el cliente en lugar de utilizar el identificador estrictamente ligado al token en la base de datos.
- **Ausencia de validación cruzada:** El backend no verificaba que el usuario solicitante del token fuera el mismo usuario cuya contraseña iba a ser modificada.

RECOMENDACIONES DE MITIGACIÓN

Vincular permanentemente el token temporal directamente al identificador del usuario en el almacenamiento del servidor (backend state), impidiendo que cualquier parámetro suministrado por el cliente altere la identidad del objetivo durante el restablecimiento.